

Introduction to Information Security

Key Security Objectives (CIA Triad)

- Confidentiality (Data Confidentiality, Privacy)
- Integrity (Data Integrity, System Integrity)
- Availability

Extended CIA Triad

- Authenticity (Data Authentication, Source Authentication)
- Accountability (Actions of an entity can be traced uniquely)

Levels of Impact

- low (limited effect)
- moderate (serious adverse effect)
- high (catastrophic effect)

Computer Security Concepts

- Assets (things we want to protect)
 - Hardware (computer)
 - Software (web server)
 - Data (files, databases, passwords)
 - Communication links (links between computers)

Computer and Network Assets, with Examples of Threats

	Availability	Confidentiality	Integrity
Hardware	Equipment is <u>stolen</u> or disabled, thus denying service.	An unencrypted CD-ROM or DVD is stolen.	
Software	Programs are deleted, denying access to users.	An unauthorized copy of software is made.	A working program is modified, either to cause it to fail during execution or to cause it to do some unintended task.
Data	Files are deleted, denying access to users.	An unauthorized read of data is performed. An analysis of statistical data reveals underlying data.	Existing files are modified or new files are fabricated.
Communication Lines and Networks	Messages are destroyed or deleted. Communication lines or networks are rendered unavailable.	Messages are read. The traffic pattern of messages is observed.	Messages are modified, delayed, reordered, or duplicated. False messages are fabricated.

Vulnerabilities, Threats & Attacks

- Vulnerability
 - Corrupted (loss of integrity – asset does not do its function)
 - Leaky (loss of confidentiality – leaks information)
 - Unavailable / Very slow (loss of availability – user can't access the asset)
- Security Policy : Set of rules & regulations that specifies how a company/organization provides security to protect assets
- Threats
 - Potential security harm to an asset
- Attack
 - A threat is carried out ; leads to violation of security policy
 - Passive – attempt to make use/learn info from system that does not impact system resources
 - Active – attempt to alter system resources /affect operation
 - Insider
 - Outsider
- Countermeasures
 - Prevent
 - Detect
 - Respond
 - Recover

Threat Action : an attack

Threat Agent : entity that attacks

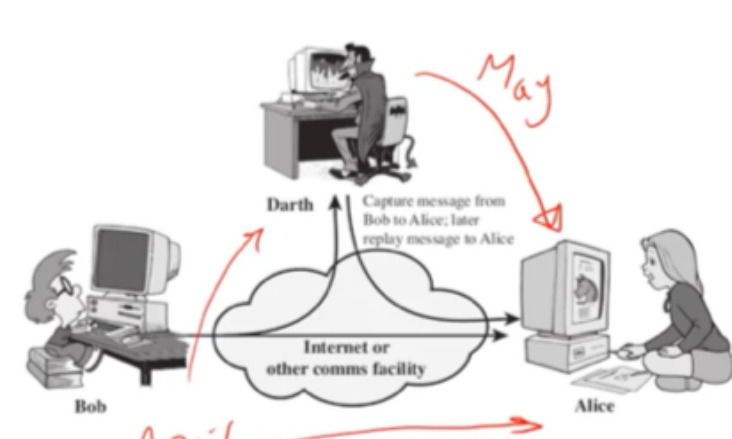
Threat Consequence : security violation resulting from threat action

Passive & Active Attacks

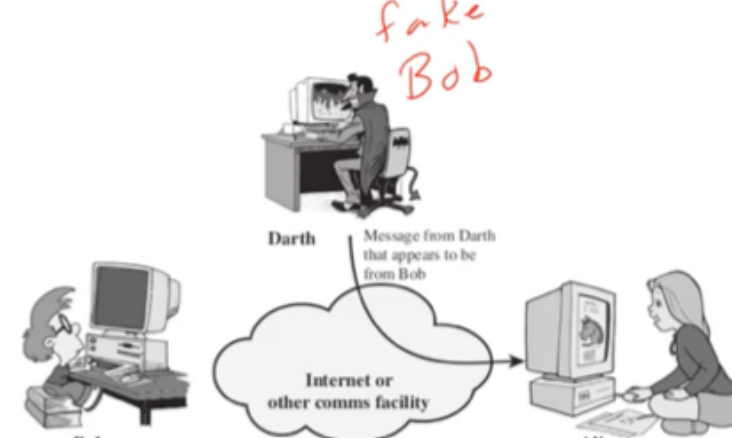
Passive Attack
- Attempts to learn or make use of information from the system but does not affect system resources - Eavesdropping on, or monitoring of, transmissions - Goal of attacker is to obtain information that is being transmitted - Two types: - Release of message contents - Traffic analysis

Active Attack
- Attempts to alter system resources or affect their operation - Involve some modification of the data stream or the creation of a false stream - Four categories: - Replay - Masquerade - Modification of messages - Denial of service

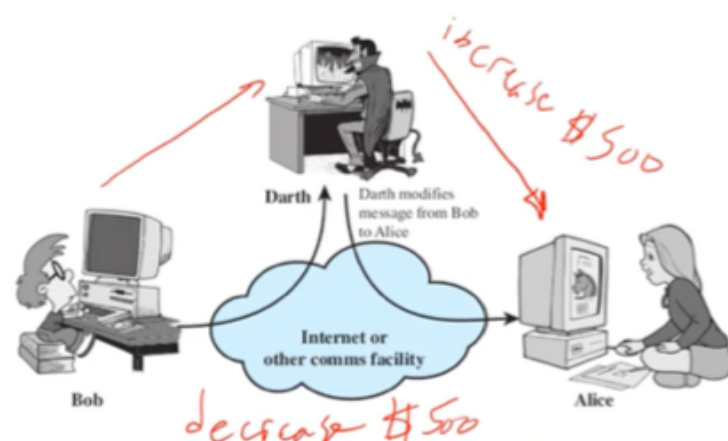
Replay Attack



Masquerade Attack



Modification Attack



Computer Security Strategy & Principles

- Policy
 - What is the security scheme supposed to do?
- Implementation
 - How does it do it? Prevention, Detection, Response, Recovery
- Assurance – degree of confidence that security measures work as intended
 - Does it really work?

Aspects of security

- Security Attack
- Security Mechanism
 - Encryption/Decryption, Digital Signature, Access Control, Data integrity, Authentication exchange, Traffic Padding
- Security Service
 - Authentication – assure communicating entity is who he says he is
 - Access Control – prevent unauthorized use of resource
 - Data Confidentiality – protect data from unauthorized disclosure
 - Data Integrity – assure data is received exactly as sent by entity
 - Non-repudiation – protect against denial of one entity being involved
 - Availability – system is accessible & usable

Attack Surface Categories

- Network – network protocol vulnerabilities
- Software – web server software
- Human – social engineering

Standards

- NIST (National Institute of Standards and Technology)
- ISOC (Internet Society)
- ITU-T (International Telecommunication Union)
- ISO (International Organization of Standardization)